

SHIVA ZEN

Sistema de Gestão para Clínica de Estética

Jaqueline Aranha Estética

Documento de Especificação de Requisitos e Modelagem UML

Versão 2.2 | 23/09/2026

Sumário

Atualize este campo no Word (Ctrl+A, F9) para gerar o sumário.

1. Introdução

1.1 Objetivo

Este documento especifica os requisitos funcionais e não funcionais, as regras de negócio e a modelagem UML do sistema Shiva Zen — plataforma web de gestão da clínica de estética Jaqueline Aranha. O conteúdo foi derivado diretamente do código-fonte da aplicação (Django 5.2, migrations até 0046), garantindo aderência ao comportamento realmente implementado.

1.2 Escopo

O sistema cobre o agendamento online público (sem senha: a cliente é identificada pelo celular, confirmado por código OTP via SMS em todo agendamento), com aceite da Política de Privacidade, consentimento para dado de saúde e termos do procedimento; a área "Meus agendamentos"; o portal do profissional; o painel administrativo (agenda, agendamento interno, clientes, prontuário com histórico, pacotes, promoções, comissões, NPS e depoimentos, termos, auditoria); rotinas automáticas (lembrete D-1, NPS, pacotes, aniversário, limpeza de status, retenção LGPD) e integrações externas (SMS Zenvia, WhatsApp Meta, e-mail, Google Calendar, Cloudflare Turnstile, Sentry).

1.3 Visão geral da arquitetura

Aplicação Django monolítica renderizada no servidor e servida por gunicorn (1 worker × 4 threads) em contêiner Docker no Railway, com PostgreSQL 18 como banco principal (invariantes garantidas por EXCLUDE, CHECK, UNIQUE parciais e triggers). As tarefas Celery rodam em modo síncrono (eager) e os jobs periódicos são disparados por um cron externo via HTTP autenticado; cache e sessão são locais, com Redis opcional. O front-end usa Vite, Tailwind CSS v4, Alpine.js (build CSP) e componentes django-cotton, com PWA. A regra de negócio reside em serviços, sinais de modelo e eventos de domínio (EventBus); o estado do atendimento é governado por uma máquina de estados (FSM). Detalhes nas seções 8 e 10.

2. Atores do Sistema

Atores identificados a partir dos papéis de acesso e dos fluxos públicos e internos.

Ator	Descrição
Visitante / Cliente (público, sem login)	Navega no site e agenda sem conta: a identidade é o celular, confirmado por código SMS em todo agendamento. Aceita a Política de Privacidade e os termos, consente o uso do dado de saúde, entra na lista de espera, responde NPS e fichas por link. Precisa ter 18 anos ou mais.
Cliente cadastrada	Cliente com cadastro ativo (mesmo celular). Entra em "Meus agendamentos" por celular ou e-mail (o código vai ao celular do cadastro), reagenda (até 24 h antes), cancela, confirma presença pelo lembrete D-1 e exerce os direitos LGPD (exportar dados, descadastrar).
Profissional	Usuário PROFISSIONAL vinculado a um profissional ativo. Usa o portal /profissional/: agenda própria, aprova/rejeita os próprios pedidos, marca realizado (com termo aceito ou override auditado), anota a sessão e lê a ficha só das clientes com vínculo. Feed iCal, Google Calendar e push. 2FA opcional (obrigatório se configurado).
Administrador (ADMIN)	Usuário ADMIN (is_staff), com 2FA obrigatório. Painel completo, incluindo as tarefas de recepção: agenda, agendamento interno, aprovação, clientes e prontuário, profissionais, catálogo, pacotes, promoções, financeiro, comissões, NPS e depoimentos, lista de espera, formulários e termos, usuários, configurações, Branding e auditoria.
Sistema / Cron externo	Agendador externo (cron-job.org ou Railway Cron) que chama POST /cron/run/<job>/ com o header X-Cron-Token: lembrete D-1, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD, housekeeping e feriados.
Serviços externos	Zenvia (SMS/OTP e status de entrega), WhatsApp Cloud API (lembrete, NPS, aviso de vaga e respostas via webhook assinado), provedor de e-mail, Cloudflare Turnstile, Google Calendar e Sentry.

3. Requisitos Funcionais

ID	Ator	Descrição
RF01	Cliente (público)	Consultar serviços, equipe, promoções (com o mesmo preço do agendamento), galeria e depoimentos autorizados.
RF02	Cliente (público)	Agendar online escolhendo procedimento, data/horário e profissional, confirmando o celular com código SMS.
RF03	Cliente (público)	No agendamento, aceitar a Política de Privacidade e os termos do procedimento, consentir o uso do dado de saúde e responder a ficha de anamnese.
RF04	Cliente (público)	Acessar "Meus agendamentos" com celular ou e-mail cadastrado (código sempre ao celular) e ver agendamentos futuros e passados.
RF05	Cliente (público)	Reagendar um atendimento até 24 h antes, escolhendo novo horário disponível.
RF06	Cliente (público)	Cancelar um atendimento futuro.
RF07	Cliente (público)	Confirmar presença ou cancelar pelo link do lembrete D-1 do WhatsApp.
RF08	Cliente (público)	Aceitar termos pendentes pelo link do atendimento.
RF09	Cliente (público)	Entrar na lista de espera e receber aviso de vaga por e-mail/WhatsApp.
RF10	Cliente (público)	Responder o NPS (0–10) e autorizar a publicação do depoimento.
RF11	Cliente (público)	Responder ficha de anamnese por link, com consentimento para dado de saúde.
RF12	Cliente (público)	Baixar os próprios dados (DSAR) com código SMS e descadastrar-se de marketing e pesquisas.
RF13	Sistema	Oferecer o WhatsApp da clínica como caminho de agendamento quando o SMS não estiver disponível.
RF14	Equipe	Entrar com e-mail e senha, cadastrar e validar 2FA (obrigatório para ADMIN) e redefinir a senha por link.
RF15	ADMIN	Aprovar ou rejeitar pedidos PENDENTES (individual ou em lote), com e-mail à cliente.
RF16	ADMIN (recepção)	Agendar pelo painel para cliente existente ou nova, com os horários do mesmo cálculo do site.
RF17	ADMIN	Operar a agenda: lista com filtros, calendário com arrastar-e-soltar, mudança de status pela FSM, valor cobrado, link do termo e override "Realizado sem termo aceito".
RF18	Profissional	Usar o portal: agenda do dia/semana, pedidos pendentes (aprovar/rejeitar), marcar realizado, anotar a sessão, ver alertas de saúde e a ficha das clientes com vínculo, ativar push.
RF19	ADMIN / Profissional	Registrar e consultar o prontuário com histórico de versões e as anotações de sessão.
RF20	ADMIN	Gerir clientes: busca, ficha com alertas, pacotes, histórico e edição validada (telefone/CPF/e-mail únicos).
RF21	ADMIN	Gerir profissionais (expediente, exceções, antecedências, novo link do feed iCal), procedimentos, preços, habilitações e bloqueios de agenda (inclusive para todos os profissionais).
RF22	ADMIN	Gerir pacotes: criar/editar, vender, acompanhar saldo e validade, cancelar com valor devolvido.
RF23	ADMIN	Gerir promoções e disparar e-mail de promoção para clientes com consentimento.
RF24	ADMIN	Acompanhar dashboard e financeiro (faturamento, faltas, rankings), pagar comissões e exportar relatório em Excel.
RF25	ADMIN	Acompanhar o NPS e aprovar ou retirar depoimentos do site.
RF26	ADMIN	Ver a lista de espera e avisar manualmente a cliente de uma vaga.
RF27	ADMIN	Gerir formulários de anamnese e termos versionados, e acompanhar a conformidade dos aceites.
RF28	ADMIN	Gerir usuários da equipe, configurações, Branding (contatos e marca), notificações e consultar a auditoria.
RF29	Sistema	Executar jobs periódicos por cron HTTP autenticado: lembrete D-1, NPS, alerta

		de detrator, pacotes, aniversário, limpeza de status, retenção LGPD, housekeeping e feriados.
RF30	Sistema	Criar automaticamente o retorno gratuito quando o procedimento exige.
RF31	Sistema	Calcular comissão, liberar/estornar cashback e debitar sessão de pacote automaticamente conforme as transições.
RF32	Sistema externo	Receber webhooks do WhatsApp (resposta de NPS) e da Zenvia (status de SMS), autenticados.
RF33	ADMIN	Consultar a API REST somente leitura (profissionais, procedimentos, clientes com PII mascarada, atendimentos) e a documentação Swagger.
RF34	Profissional	Assinar o feed iCal da própria agenda e conectar o Google Calendar.

4. Requisitos Não Funcionais

ID	Categoria	Descrição
RNF01	Segurança	Content-Security-Policy com nonce por request, sem unsafe-inline em script-src/style-src e sem handlers inline; libs de CDN só por caminho versionado e com SRI; frame-ancestors none (exceto o widget).
RNF02	Segurança	HTTPS obrigatório com HSTS de 1 ano (preload), X-Frame-Options DENY, nosniff, COOP/CORP, Permissions-Policy e cookies HttpOnly/SameSite/Secure.
RNF03	Segurança	2FA TOTP obrigatório para ADMIN, conferido a cada request em painel, API, Django admin e push; sem tela de login paralela; recuperação só por comando no servidor.
RNF04	Segurança	OTP com HMAC-SHA256 e a SECRET_KEY, comparação em tempo constante, 5 tentativas, propósitos isolados e desafio preso ao telefone.
RNF05	Segurança	Rate-limit em camadas: cotas de SMS (telefone, IP, global), limites por IP nos endpoints públicos, django-axes no login, throttling da API; captcha Turnstile no pedido de código.
RNF06	Privacidade	Áreas privadas sem cache no navegador (no-store), Referrer-Policy no-referrer nas rotas com token, Clear-Site-Data no logout, tokens redigidos no access log e no Sentry.
RNF07	Segurança	Segredos só em variáveis de ambiente; SECRET_KEY obrigatória fora de DEBUG; DJANGO_ENV inválido derruba o boot; system checks (aranha.W001–W009) apontam configuração de produção faltando.
RNF08	Confiabilidade	Canais de mensagem falham fechado: sem credencial nada é enviado nem marcado como enviado; I/O externo só após o commit.
RNF09	LGPD	Consentimentos granulares com data e IP; aceite da política e dos termos com prova (IP, navegador, SHA-256); consentimento específico para dado de saúde (art. 11).
RNF10	LGPD	Retenção automatizada (OTP, notificações, auditoria, logs de login, clientes inativas/excluídas, fichas de pedidos não realizados, lista de espera) e direito ao esquecimento com pseudonimização.
RNF11	LGPD	Direitos do titular: acesso/portabilidade (DSAR em JSON), correção pela clínica, revogação de consentimento, anonimização.
RNF12	LGPD	Trilha de auditoria com autor, IP e detalhes mascarados; PII mascarada em logs, API e Sentry (send_default_pii=False).
RNF13	Integridade	Invariantes no banco: EXCLUDE anti double-booking, UNIQUE parciais, CHECKS, triggers de imutabilidade (ledger, prova de aceite, termo aceite, histórico do prontuário) e FKs PROTECT no histórico clínico/financeiro.
RNF14	Confiabilidade	Migrações aplicadas numa transação única com lock_timeout no pre-deploy (tudo ou nada); rollback de produção por restauração do backup.
RNF15	Confiabilidade	FSM com transições validadas sob lock e auditadas; efeitos idempotentes (1 retorno por origem, 1 consumo e 1 comissão por atendimento, cashback único).
RNF16	Desempenho	gunicorn 1 worker × 4 threads com cache local (Redis opcional para escalar); estáticos comprimidos e com hash (WhiteNoise); cache do Branding; índices compostos para agenda e relatórios.
RNF17	Observabilidade	Healthchecks /healthz/ (liveness + build do front) e /health/ (banco, cache, front); Sentry opcional; logs JSON em produção.
RNF18	Qualidade	Cerca de 1.060 testes automatizados; CI com SQLite, Postgres 18 (bloqueante), build do front, build da imagem Docker e auditoria de dependências.
RNF19	Usabilidade	Interface pt-BR em tom de estética e bem-estar; contraste AA nos tokens; wizard operável por teclado; tema claro/escuro; PWA instalável para o site e para a equipe.
RNF20	Manutenibilidade	Camadas views → services/utils → models; fontes únicas (SlotService, preços, Branding, termos); componentes cotton e Alpine CSP; documentação viva e requisitos gerados a partir de dados versionados.
RNF21	Implantação	Imagem Docker multi-stage (Node para o front, Python para a app) com dependências fixadas (requirements.lock), usuário não-root e healthcheck; deploy no Railway com pre-deploy de migração e criação do ADMIN.

5. Regras de Negócio

ID	Título	Descrição
RN01	Papéis da equipe	Usuario.papel = ADMIN, PROFISSIONAL ou RECEPCAO (CHECK). ADMIN (is_staff) tem o painel completo; PROFISSIONAL vinculado a um profissional ativo usa o portal /profissional/; RECEPCAO não tem login até existirem telas próprias. A cliente nunca é usuária.
RN02	Identidade da cliente pelo celular	A cliente não tem conta nem senha: a identidade é o telefone (só dígitos, 10–11, sem DDI), único entre clientes ativos (UNIQUE parcial). E-mail e CPF são opcionais e também únicos entre ativos. O e-mail digitado nunca é identidade.
RN03	Idade mínima	O agendamento online exige data de nascimento e idade mínima de 18 anos.
RN04	Bloqueio online por faltas	Cada falta soma em faltas_consecutivas; ao atingir o limite (Configuracao MAX_FALTAS_BLOQUEIO, padrão 3) a cliente fica bloqueada para agendar online. Comparecer (REALIZADO) zera o contador e desbloqueia. A clínica ainda pode agendar pelo painel.
RN05	Exclusão lógica da cliente	Excluir cliente é soft delete (deletado_em); exclusão física só explícita. A anonimização segue a RN40/RN41.
RN06	Fluxo do agendamento público	Procedimento → data/horário → dados + código SMS → confirmar. O servidor revalida tudo no confirmar: procedimento/profissional ativos, habilitação, data futura, feriado, slot livre para a duração inteira, ficha e aceites. Sem provedor de SMS o agendamento online fica indisponível e o botão Agendar leva ao WhatsApp.
RN07	Antecedência mínima	Por profissional: min_notice_horas (padrão 2 h, faixa 0–720).
RN08	Antecedência máxima	Por profissional: max_advance_dias (padrão 60 dias, faixa 1–365). Não há teto global.
RN09	Cálculo de disponibilidade	SlotService (fonte única): slots de 30 min considerando feriado, exceção (folga/horário diferente), expediente semanal, atendimentos ativos sobrepostos na duração inteira + buffer do procedimento, bloqueios pontuais/recorrentes do profissional ou globais, antecedência mínima e máxima.
RN10	Anti double-booking	Um profissional não pode ter dois atendimentos ativos sobrepostos: trava de 30 s no cache, SELECT FOR UPDATE e constraint EXCLUDE no Postgres. Corrida perdida gera a mensagem "Este horário acabou de ser reservado".
RN11	Pedido público nasce PENDENTE	O agendamento público entra como PENDENTE; a clínica aprova (AGENDADO + e-mail de confirmação) ou rejeita (CANCELADO + e-mail), no painel (individual ou em lote) ou no portal do profissional. PENDENTE vencido há 24 h é cancelado pelo job de limpeza.
RN12	Agendamento interno	A recepção agenda pelo painel (cliente existente ou nova com telefone validado) usando o mesmo SlotService; não há OTP; o atendimento nasce AGENDADO e o valor pode ser ajustado (fica registrado).
RN13	Preço gravado com promoção da data	O atendimento grava o preço vigente na data do atendimento (profissional > base) com a promoção que vale nesse dia: valor_cobrado, valor_original, promoção e descrição. Vitrine e resumo mostram exatamente esse valor.
RN14	Aceite da Política de Privacidade	Obrigatório no agendamento; grava AceiteTermo da versão LGPD vigente com IP, navegador e SHA-256 do texto aceito.
RN15	Consentimento para dado de saúde (art. 11)	A ficha de anamnese (no wizard ou pelo link público) só é gravada com a caixa de consentimento específica marcada; o texto do consentimento, a data e o IP vão para a auditoria.
RN16	Termos de procedimento	Termos do procedimento (próprio e gerais) são aceitos no wizard; versão já aceita não é pedida de novo. Faltando aceite, o atendimento mostra "Termo pendente" e a clínica gera o link do termo, válido até o fim do atendimento. Marcar REALIZADO com termo pendente exige o override explícito "Realizado sem termo aceito", auditado.
RN17	Consentimentos de comunicação	E-mail marketing, lembrete por WhatsApp e pesquisa por WhatsApp nunca vêm pré-marcados; conceder e revogar gravam data e IP. O descadastro por link desliga marketing e pesquisas e mantém o lembrete D-1 (aviso do serviço).

RN18	Código OTP	Código de 6 dígitos (secrets), armazenado como HMAC-SHA256 com a SECRET_KEY, nunca em texto; validade 10 min; 5 tentativas; reenvio mínimo de 60 s; gerar um novo invalida o anterior; comparação em tempo constante.
RN19	OTP preso ao telefone	Todo agendamento público exige o código enviado ao celular informado (só celular recebe SMS). Cotas de SMS: 3/h por telefone, 10/h por IP, 60/h global, checadas antes de gerar o código. Propósitos isolados (AGENDAMENTO, LOGIN_CLIENTE, DSAR). Respostas não revelam se o telefone é cadastrado.
RN20	Máquina de estados do atendimento	PENDENTE → AGENDADO/CONFIRMADO/CANCELADO/REAGENDADO; AGENDADO → CONFIRMADO/REALIZADO/CANCELADO/FALTOU/REAGENDADO; CONFIRMADO → REALIZADO/CANCELADO/FALTOU/REAGENDADO; REALIZADO, CANCELADO, FALTOU e REAGENDADO são terminais. AGENDADO = horário aprovado; CONFIRMADO = a cliente confirmou.
RN21	Reagendamento pela cliente	Permitido até 24 h antes. O atendimento antigo vira REAGENDADO antes de o novo entrar; o novo herda preço, promoção, vínculo de retorno e a ficha de anamnese. Fica AGENDADO se o original estava aprovado e a profissional é a mesma; senão volta a PENDENTE.
RN22	Cancelamento pela cliente	Pelo token do atendimento (portal ou link), a qualquer momento antes do início, pela FSM.
RN23	Lembrete D-1 e confirmação de presença	Às 08:00 o sistema envia WhatsApp (template aprovado) aos atendimentos AGENDADO do dia seguinte com consentimento de lembrete; o link permite confirmar (→ CONFIRMADO) ou cancelar, uma única vez.
RN24	Faltas	Só a equipe marca FALTOU. O job diário não marca falta: atendimentos sem desfecho vão para o log. Não há cobrança de taxa de no-show.
RN25	Retorno obrigatório (F-RET)	Procedimento com exige_retorno gera, ao REALIZADO, um atendimento de retorno PENDENTE com valor 0 no primeiro horário livre da janela [mínimo, máximo] a partir do meio. Sem horário livre, não cria. No máximo 1 retorno vivo por origem (UNIQUE). Retorno não gera comissão, cashback nem débito de pacote.
RN26	Pacotes — consumo	Sessão REALIZADA de procedimento do pacote debita 1 sessão do pacote que vence primeiro (1 consumo por atendimento). A validade é conferida na data da sessão. Pacote vendido tem nome e itens congelados.
RN27	Pacotes — ciclo de vida	ATIVO → FINALIZADO (todas as sessões usadas), EXPIRADO (job diário, vencimento < hoje) ou CANCELADO (exige valor devolvido entre 0 e o valor pago e motivo, auditados). Aviso por e-mail 7 e 1 dia antes do vencimento com saldo.
RN28	Promoções e preços	Preço versionado por vigência (data local). Promoção = desconto 0–100% XOR preço fixo (CHECK), por período; promoção geral só vale como percentual; aplica-se só quando reduz o valor e nunca deixa negativo.
RN29	Valor cobrado e faturamento	A clínica pode registrar o valor combinado (não em cancelado/faltou/reagendado, retorno ou realizado com comissão lançada). Faturamento = avulsos realizados com valor > 0 + vendas de pacote na data da compra; sessão de pacote e retorno não somam.
RN30	Comissão	Calculada ao REALIZADO (não em retorno) pela regra mais específica (profissional+procedimento > profissional > procedimento > global; empate = mais recente): percentual 0–100 ou valor fixo sobre o valor cobrado, ou, em sessão de pacote, valor pago ÷ total de sessões. 1 comissão ativa por atendimento; cancelamento estorna.
RN31	Cashback por indicação	No 1º atendimento REALIZADO e pago da indicada, a indicadora recebe R\$ 50,00 na carteira (idempotente); cancelamento estorna; saldo nunca negativo; ledger imutável.
RN32	Lista de espera	Um pedido ativo por cliente/procedimento/data. Quando um atendimento ativo futuro vira CANCELADO ou REAGENDADO, todos os pedidos compatíveis recebem e-mail e WhatsApp (com consentimento) com link para agendar, sem reserva do horário; notificado só com entrega. O e-mail digitado no formulário anônimo fica só na inscrição.
RN33	NPS	WhatsApp de NPS entre 24 h e 7 dias após o REALIZADO, com consentimento e

		sem opt-out geral (até 3 tentativas); link válido por 7 dias; 1 avaliação por atendimento; nota 0–10. Nota ≤ 6 gera alerta por e-mail à clínica.
RN34	Depoimentos	Só aparecem no site com opt-in da cliente, aprovação da clínica, nota ≥ 9 e comentário; nome exibido abreviado; cliente excluída ou anonimizada nunca aparece.
RN35	Aniversário e promoções por e-mail	Aniversário = e-mail de felicitação sem desconto, com consentimento de marketing. Disparo de promoção: sem cupom, validade anunciada até o fim da promoção, só para quem consentiu, com link de descadastro, em lotes de 25.
RN36	Prontuário e histórico	Ficha 1:1 com campos clínicos e perguntas configuráveis. Cada edição grava antes a versão anterior (histórico append-only, imutável); edição concorrente é recusada; POST parcial não apaga campos.
RN37	Acesso do profissional à ficha	O profissional só lê a ficha de quem tem atendimento REALIZADO nos últimos 180 dias ou ativo entre ontem e +60 dias (escrita sem PENDENTE); ADMIN lê todas. Toda leitura, gravação e negativa é auditada.
RN38	Alertas de saúde	Alergias, contraindicações, medicamentos e respostas de risco declaradas nas fichas aparecem como texto visível no portal, na agenda do painel e na ficha da cliente; marcador "ficha pendente" quando a ficha obrigatória não foi respondida.
RN39	Termos versionados e imutáveis	1 versão ativa por escopo (LGPD global; PROCEDIMENTO geral ou por procedimento). Versão com aceite não pode ser editada (model + trigger): mudar = publicar nova versão. O aceite é imutável e nunca apagado.
RN40	Retenção de dados	OTP 24 h; texto de notificação 12 meses; auditoria 5 anos; logs de login 90 dias; cliente sem atendimento há 5 anos ou excluída há 30 dias é anonimizada, exceto com prontuário com conteúdo, pacote comprado ou atendimento realizado nos últimos 20 anos; ficha de pedido não realizado apagada após 90 dias; lista de espera vencida apagada.
RN41	Direito ao esquecimento	Anonimiza nome ([ANONIMIZADO-pk]), contatos, documentos e consentimentos; soft delete; apaga OTPs, lista de espera, texto de notificações e fichas que não são de atendimento realizado; retira o depoimento e o comentário do NPS; pseudonimiza o nome nos textos da auditoria. Atendimentos, aceites, prontuário e pacotes ficam ligados a titular não identificável.
RN42	Acesso aos dados (DSAR)	A cliente baixa os próprios dados em JSON em /lgpd/meus-dados/ com código SMS (propósito DSAR); resposta idêntica exista ou não o cadastro; ação auditada.
RN43	Auditoria	Toda ação sensível grava autor (+ nome), tabela, registro, detalhes com PII mascarada e IP (LGPD art. 37).
RN44	Login da equipe e 2FA	E-mail + senha (mínimo 10, validadores do Django). 2FA TOTP obrigatório para ADMIN (cadastro forçado após o login, conferido a cada request); opcional para PROFISSIONAL. Trocar de aparelho exige o código atual; recuperação por comando setup_2fa --force. Sessão da equipe de 8 h deslizantes; logout só via POST.
RN45	Bloqueio de login e reset de senha	django-axes bloqueia por 1 h após 5 falhas (IP + usuário); rate-limit no login. Reset de senha com token de 1 h, 3 pedidos/15 min por IP, resposta genérica; sem backend de e-mail real nada é enviado.

6. Casos de Uso

Diagrama de Casos de Uso (UML) – Área Pública (Cliente)

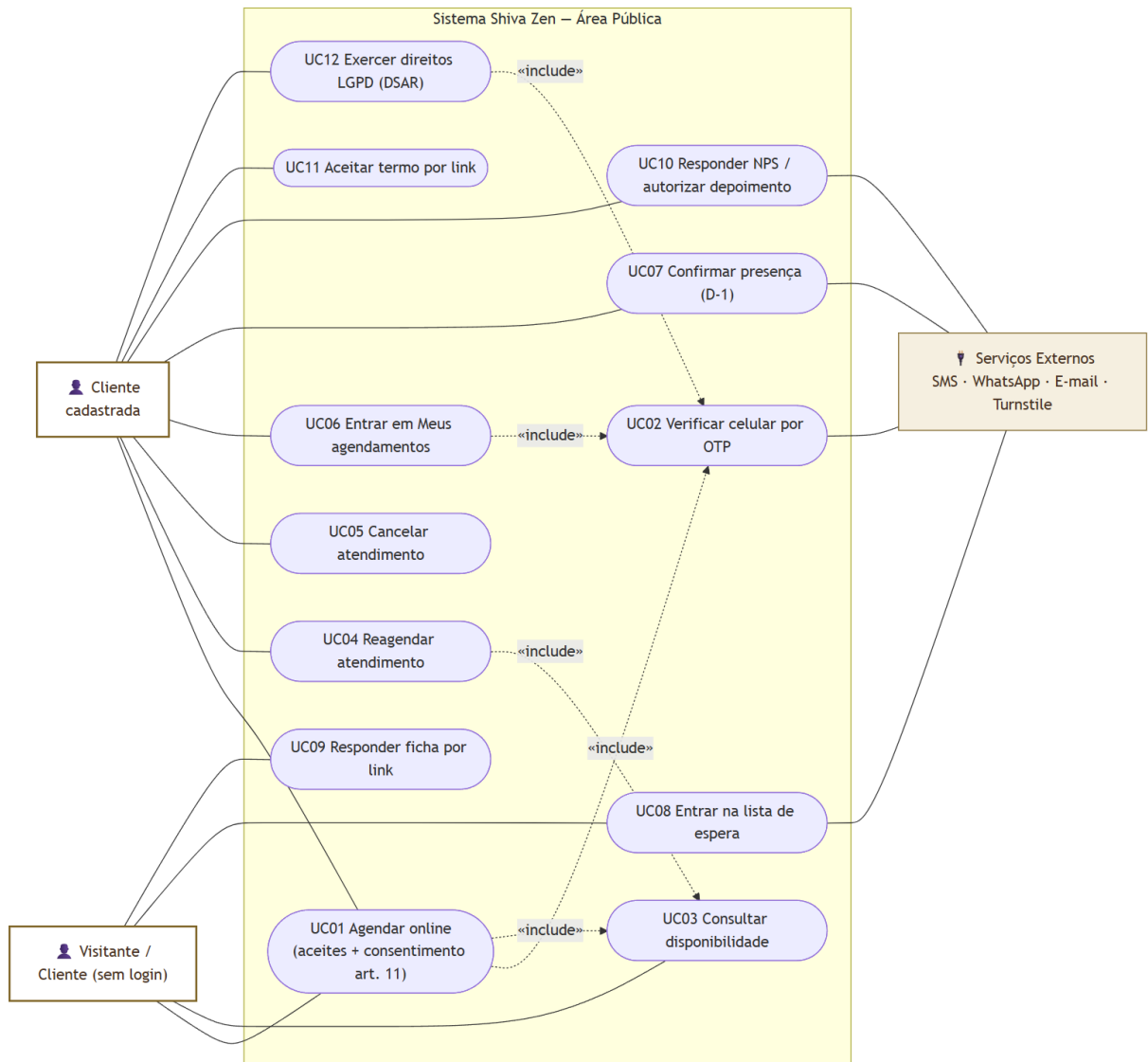


Figura 1 — Diagrama de Casos de Uso (UML): Área Pública (Cliente).

Diagrama de Casos de Uso (UML) – Área Interna (ADMIN, Profissional, Sistema)

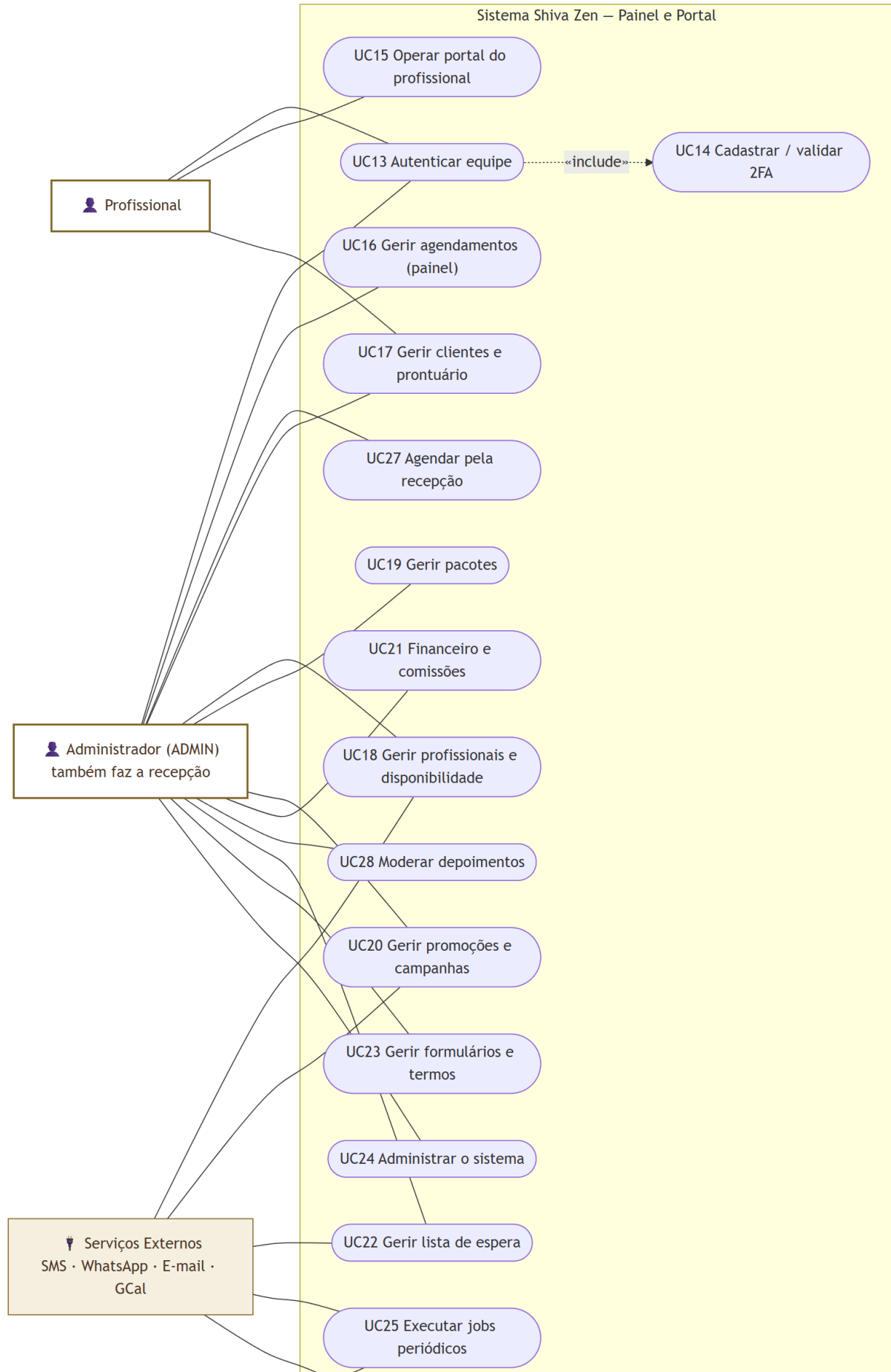


Figura 2 — Diagrama de Casos de Uso (UML): Área Interna (ADMIN, Profissional, Sistema).

6.1 Especificação dos casos de uso

ID	Caso de Uso	Atores	Fluxo principal
UC01	Agendar online	Visitante / Cliente (público, sem login), Cliente cadastrada, Serviços externos	Cliente escolhe procedimento, data/horário e profissional, informa dados, aceita a política e os termos, consente o dado de saúde e responde a ficha; confirma o celular com código SMS (UC02). O servidor revalida slot, habilitação, feriado, idade ≥ 18 e aceites; trava o slot (cache + SELECT FOR UPDATE + EXCLUDE), cria/atualiza a cliente pelo telefone, grava o atendimento PENDENTE com o preço da data, os aceites com prova, a ficha e o consentimento na auditoria; avisa o profissional.
UC02	Verificar celular por OTP	Visitante / Cliente (público, sem login), Cliente cadastrada, Serviços externos	Cliente informa o celular; o sistema valida o captcha (se configurado), recusa telefone fixo, checa intervalo e cotas de SMS, gera o código (HMAC) e envia pela Zenvia. A cliente digita o código; o sistema confere (5 tentativas) e marca o telefone como verificado na sessão por 30 min, devolvendo o pré-preenchimento do cadastro daquele telefone.
UC03	Consultar disponibilidade	Visitante / Cliente (público, sem login)	O wizard consulta dias do mês e horários livres; o SlotService calcula os slots de 30 min por profissional considerando expediente, exceções, feriados, bloqueios, atendimentos, buffer e antecedências.
UC04	Reagendar atendimento	Cliente cadastrada	Pelo token do atendimento: exige ≥ 24 h de antecedência; escolhe novo horário (UC03); o antigo vira REAGENDADO e o novo herda preço, retorno e ficha; fica AGENDADO se já aprovado e com a mesma profissional, senão PENDENTE.
UC05	Cancelar atendimento	Cliente cadastrada	Pelo token (portal): atendimento ativo e futuro vai para CANCELADO pela FSM; a vaga é oferecida à lista de espera.
UC06	Entrar em Meus agendamentos	Cliente cadastrada, Serviços externos	Cliente informa celular ou e-mail; se houver cadastro, o código vai ao celular do cadastro (resposta sempre igual); após o código, sessão de 1 h presa ao telefone com agendamentos futuros e passados, reagendar e cancelar.
UC07	Confirmar presença	Cliente cadastrada	Pelo link do lembrete D-1 (WhatsApp): confirmar (AGENDADO → CONFIRMADO) ou cancelar, uma única vez.
UC08	Entrar na lista de espera	Visitante / Cliente (público, sem login)	Informa nome, celular, procedimento, data, turno/profissional e e-mail opcional; sistema normaliza o telefone e registra o pedido (e-mail só na inscrição). Quando uma vaga compatível abre, recebe aviso por e-mail/WhatsApp.
UC09	Responder ficha de anamnese por link	Visitante / Cliente (público, sem login)	Pelo token (60 dias): responde a ficha; para ficha de saúde marca o consentimento do art. 11 (auditado); respostas validadas contra o schema; uma resposta por link.
UC10	Responder NPS	Cliente cadastrada, Serviços externos	Pelo link (7 dias) ou respondendo o WhatsApp: nota 0–10, comentário e autorização do depoimento; uma avaliação por atendimento.
UC11	Aceitar termo por link	Cliente cadastrada	Pelo link do atendimento (válido até o fim dele): lê e aceita os termos pendentes; o aceite grava IP, navegador e SHA-256 do texto.

UC12	Exercer direitos LGPD	Cliente cadastrada, Serviços externos	Baixar os dados em JSON após código SMS (DSAR), descadastrar-se por link e registrar o aviso de cookies.
UC13	Autenticar equipe	Administrador (ADMIN), Profissional	Login por e-mail/senha com rate-limit e django-axes; ADMIN sem 2FA vai ao cadastro obrigatório; com 2FA passa pelo desafio (UC14); reset de senha por link (1 h). Logout só via POST.
UC14	Cadastrar / validar 2FA	Administrador (ADMIN), Profissional	Cadastro por QR (SVG) e confirmação do primeiro código; desafio a cada sessão (TOTP ou código de backup); trocar de aparelho exige o código atual.
UC15	Operar o portal do profissional	Profissional	Agenda do dia/semana e pedidos pendentes com alertas de saúde; aprovar/rejeitar; marcar realizado (termo aceito ou override auditado); anotar a sessão; abrir a ficha quando há vínculo.
UC16	Gerir agendamentos no painel	Administrador (ADMIN)	Lista com filtros e marcadores (termo pendente, ficha pendente, alertas); aprovar/rejeitar individual ou em lote; mudar status pela FSM (409 sem termo, salvo override); calendário com arrastar-e-soltar; valor cobrado; link do termo.
UC17	Gerir clientes e prontuário	Administrador (ADMIN), Profissional	Ficha da cliente (dados validados, alertas, pacotes, histórico); prontuário com histórico de versões, trava de edição concorrente e trilha de leitura; anotações de sessão.
UC18	Gerir profissionais e disponibilidade	Administrador (ADMIN), Serviços externos	Profissionais (expediente, antecedências, habilitações, preços), exceções, bloqueios (inclusive globais), procedimentos, novo link do feed iCal e conexão com o Google Calendar.
UC19	Gerir pacotes	Administrador (ADMIN)	Criar/editar pacotes (congelados após a venda), vender a uma cliente, acompanhar saldo/validade e cancelar com valor devolvido.
UC20	Gerir promoções e campanhas	Administrador (ADMIN), Serviços externos	CRUD de promoções (percentual XOR preço fixo, período) e disparo de e-mail em lotes para clientes com consentimento, sem cupom.
UC21	Financeiro e comissões	Administrador (ADMIN)	Dashboard e financeiro (faturamento de avulsos + vendas de pacote, faltas, rankings), comissões pendentes/pagas (pagar) e exportação em Excel.
UC22	Gerir lista de espera	Administrador (ADMIN), Serviços externos	Ver pedidos com contatos e avisar manualmente uma vaga por e-mail.
UC23	Gerir formulários e termos	Administrador (ADMIN)	Formulários de anamnese (schema JSON; mudar schema com respostas cria nova versão) e termos versionados (1 ativo por escopo; imutáveis após aceite); painel de conformidade dos aceites.
UC24	Administrar o sistema	Administrador (ADMIN)	Usuários da equipe (link para definir senha, ativar/desativar), configurações, Branding, notificações, pré-visualização de e-mails e auditoria.
UC25	Executar jobs periódicos	Sistema / Cron externo, Serviços externos	POST /cron/run/<job>/ com X-Cron-Token executa o job (lembrete D-1, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD, housekeeping, feriados); 500 quando o job falha.
UC26	Receber webhooks	Serviços externos, Sistema / Cron externo	WhatsApp: handshake e eventos assinados (captura nota de NPS). Zenvia: status de entrega com IP permitido e/ou HMAC.
UC27	Agendar pela recepção	Administrador (ADMIN)	Buscar cliente ou cadastrar nova (telefone validado), escolher procedimento, profissional habilitado e horário do SlotService; valor com promoção ou combinado; atendimento nasce AGENDADO, auditado; aviso de ficha pendente.
UC28	Moderar depoimentos	Administrador (ADMIN)	No painel de NPS, aprovar (só com opt-in da cliente e

			comentário) ou retirar depoimentos do site; auditado.
--	--	--	---

7. Modelo de Domínio (Diagrama de Classes)

Diagrama de Classes (UML) – Núcleo de Agendamento

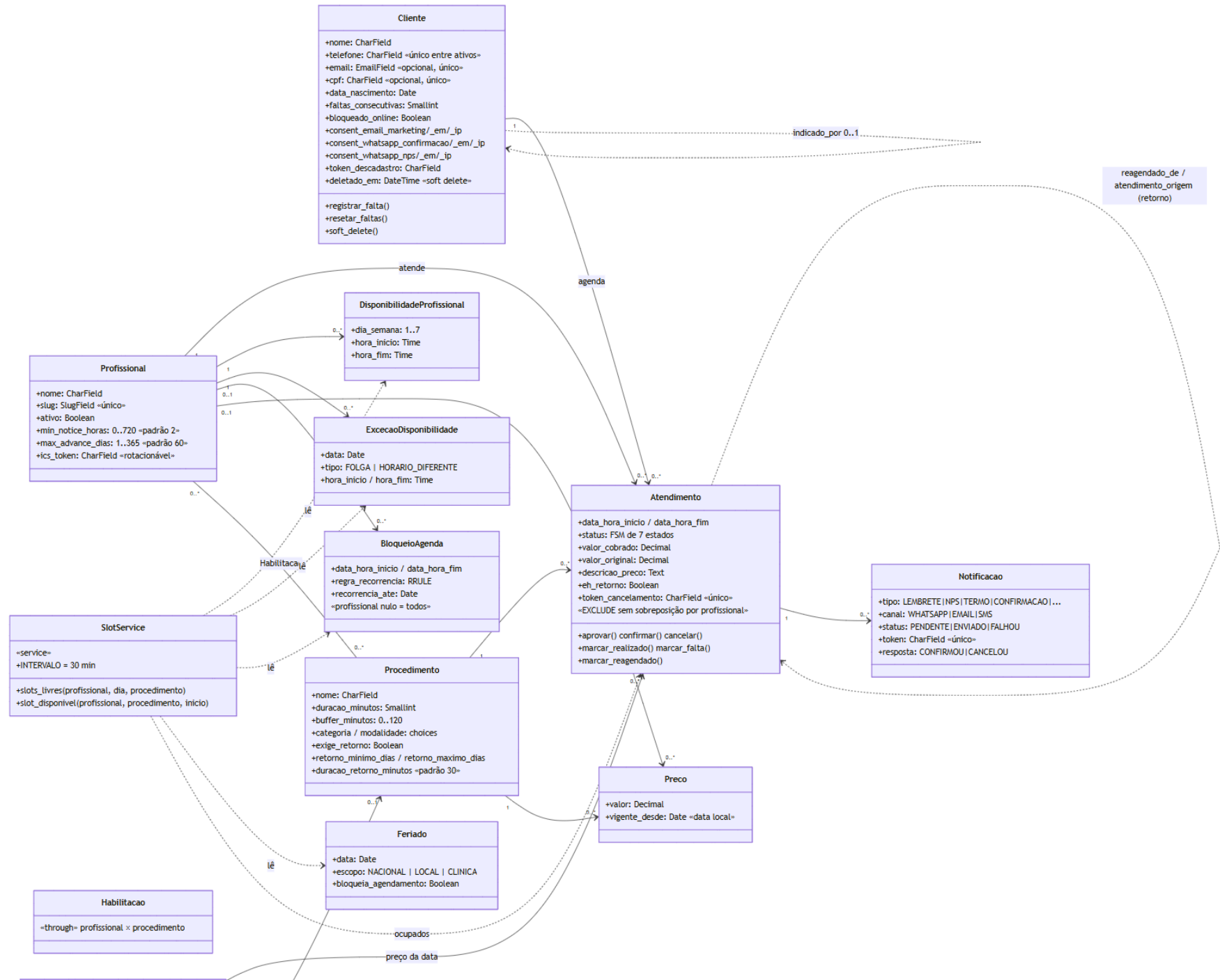


Figura 3 — Diagrama de Classes (UML): Núcleo de Agendamento.

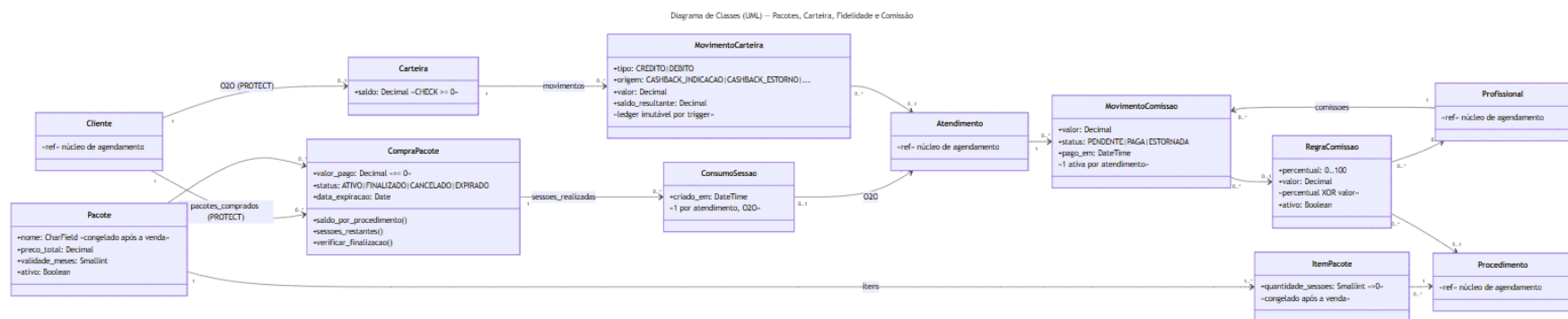


Figura 4 — Diagrama de Classes (UML): Pacotes, Carteira, Fidelidade e Comissão.

Diagrama de Classes (UML) – Prontuário, Anamnese, NPS, Termos, Acesso e Auditoria

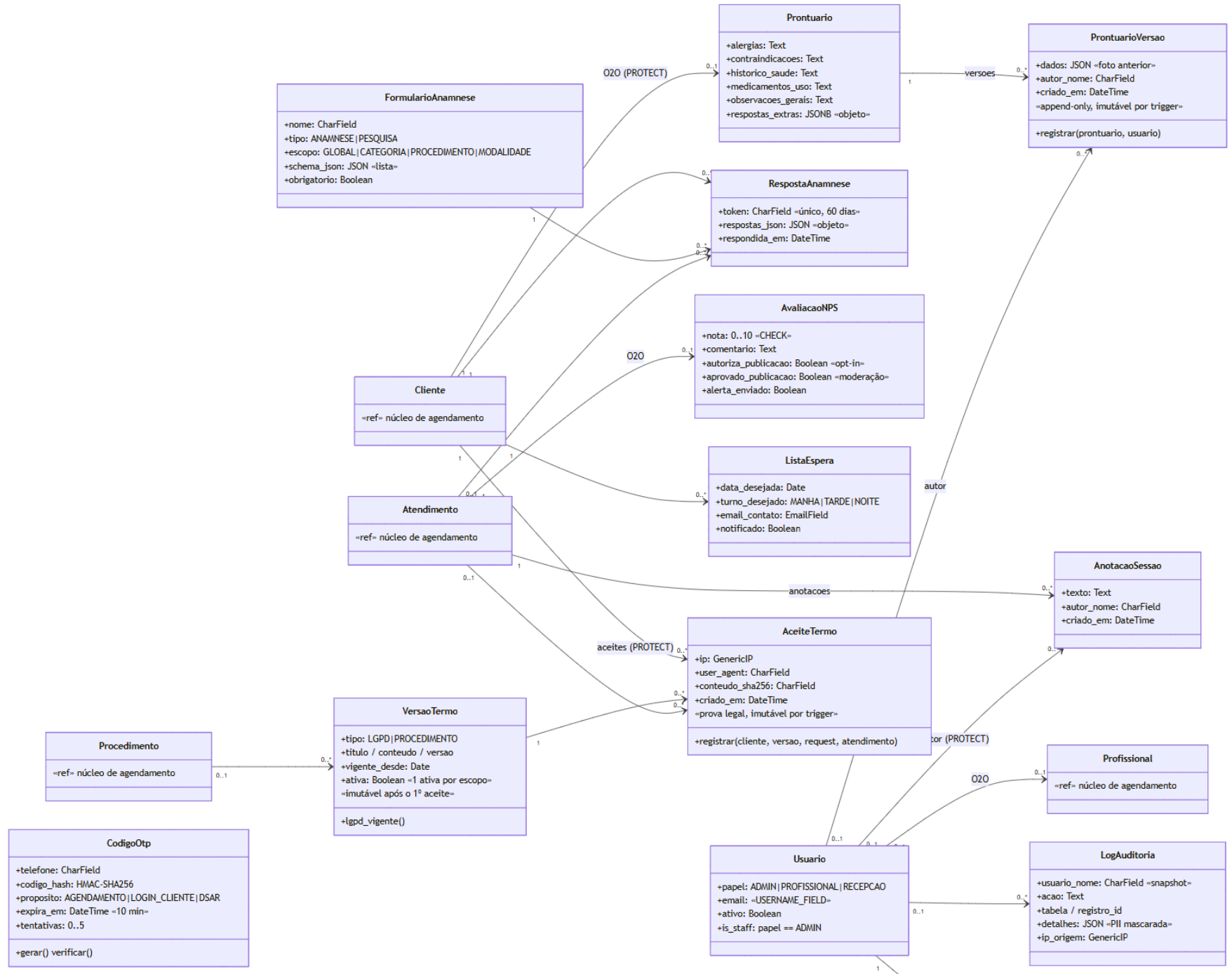


Figura 5 — Diagrama de Classes (UML): Prontuário, Anamnese, NPS, Termos, Acesso e Auditoria.

7.1 Dicionário de entidades

Entidade	Tabela	Descrição
Cliente	cliente	Cliente da clínica: identidade pelo celular (só dígitos, único entre ativos), e-mail/CPF opcionais, consentimentos granulares com data e IP, contador de faltas e bloqueio online, indicação (cashback) e soft delete.
Profissional	profissional	Profissional que atende: antecedência mínima (min_notice_horas) e máxima (max_advance_dias) do agendamento, token do feed iCal (rotacionável) e integração com o Google Calendar.
DisponibilidadeProfissional	disponibilidade_profissional	Expediente semanal recorrente do profissional (1=Dom ... 7=Sáb, vários turnos por dia).
BloqueioAgenda	bloqueio_agenda	Bloqueio de agenda pontual ou recorrente (RRULE) de um profissional ou global (profissional nulo = todos).
ExcecaoDisponibilidade	excecao_disponibilidade	Exceção pontual ao expediente numa data: FOLGA (dia bloqueado) ou HORARIO_DIFERENTE.
Procedimento	procedimento	Serviço do catálogo: duração, buffer (0–120 min), categoria, modalidade e regra de retorno obrigatório (janela em dias e duração do retorno).
Habilitacao	habilitacao	Liga profissional e procedimento (M2M through): só profissional habilitado atende o procedimento.
Preco	preco	Preço versionado por vigência (vigente_desde, data local), base (sem profissional) ou por profissional.
Promocao	promocao	Promoção por período: desconto percentual (0–100) XOR preço fixo; procedimento nulo = promoção geral (só percentual vale).
Atendimento	atendimento	Agendamento/sessão: cliente, profissional, procedimento, período, preço gravado (valor_cobrado, valor_original, promoção, descrição), retorno (eh_retorno + origem), reagendado_de e FSM de 7 estados.
Notificacao	notificacao	Mensagem ligada a um atendimento (LEMBRETE D-1, NPS, TERMO, CONFIRMACAO, CANCELAMENTO, APROVACAO...), por canal, com status PENDENTE/ENVIADO/FALHOU e token do link público.
Pacote	pacote	Pacote de sessões com preço total e validade em meses; nome e itens congelados após a 1ª venda.
ItemPacote	item_pacote	Item do pacote: procedimento e quantidade de sessões.
CompraPacote	compra_pacote	Venda de pacote a uma cliente: valor pago, status ATIVO/FINALIZADO/CANCELADO/EXPIRADO e data de expiração.
ConsumoSessao	consumo_sessao	Consumo de 1 sessão de uma compra de pacote por um atendimento REALIZADO (OneToOne com o atendimento).
Prontuario	prontuario	Ficha base 1:1 da cliente: alergias, contraindicações, histórico, medicamentos, observações e perguntas configuráveis (respostas_extras JSONB).
ProntuarioVersao	prontuario_versao	Histórico append-only do prontuário: foto do estado anterior a cada edição, com autor e data (imutável no model e por trigger no PG).
AnotacaoSessao	anotacao_sessao	Anotação clínica de um atendimento, com autor preservado (PROTECT + snapshot autor_nome).
FormularioAnamnese	formulario_anamnese	Modelo de questionário (ANAMNESE pré-atendimento ou PESQUISA) em schema JSON, com escopo (global, categoria, procedimento, modalidade) e flag

		obrigatório.
RespostaAnamnese	resposta_anamnese	Ficha respondida pela cliente (JSON), ligada ao atendimento; token do link público (60 dias).
AvaliacaoNPS	avaliacao_nps	Avaliação NPS 0–10 de um atendimento, comentário, opt-in de publicação da cliente e aprovação da clínica (depoimento).
ListaEspera	lista_espera	Pedido de aviso de vaga: procedimento, data, turno, profissional opcional e e-mail de contato da inscrição.
LogAuditoria	log_auditoria	Trilha de auditoria (LGPD art. 37): autor + snapshot do nome, ação, tabela, registro, detalhes JSON com PII mascarada e IP.
Feriado	feriado	Feriado ou recesso (nacional, local ou da clínica) que pode bloquear o agendamento.
Configuracao	configuracao	Chave-valor editável no painel: campos do Branding, email_admin, prontuario_perguntas e MAX_FALTAS_BLOQUEIO.
CodigoOtp	codigo_otp	Desafio OTP de 6 dígitos (HMAC-SHA256 com a SECRET_KEY), preso ao telefone, com propósito (AGENDAMENTO, LOGIN_CLIENTE, DSAR), validade e tentativas.
Usuario	usuario	Usuário da equipe (login por e-mail): papel ADMIN, PROFISSIONAL ou RECEPCAO (sem login); is_staff = ADMIN.
Carteira	carteira	Saldo de crédito da cliente (hoje só cashback de indicação e estorno); CHECK saldo >= 0.
MovimentoCarteira	movimento_carteira	Lançamento do ledger da carteira (crédito/débito, origem, saldo resultante); imutável por trigger.
RegraComissao	regra_comissao	Regra de comissão por profissional e/ou procedimento: percentual (0–100) XOR valor fixo.
MovimentoComissao	movimento_comissao	Comissão de um atendimento realizado: valor, status PENDENTE/PAGA/ESTORNADA.
VersaoTermo	versao_termo	Termo versionado (LGPD global ou PROCEDIMENTO); 1 versão ativa por escopo; imutável depois do 1º aceite.
AceiteTermo	aceite_termo	Prova de aceite de termo: cliente, versão, atendimento, IP, navegador, SHA-256 do texto e data; imutável (trigger no PG).
AssinaturaPush	assinatura_push	Inscrição Web Push (VAPID) de um usuário da equipe.
TimestampedMixin [ABSTRATO]	(abstract — sem tabela)	ABSTRATO: adiciona criado_em + atualizado_em (usado por Carteira e RegraComissao).

8. Diagrama de Estados — Atendimento (FSM)

O status do atendimento é governado por uma máquina de estados finitos; transições inválidas levantam exceção tipada (`Atendimento.TransicaoInvalida`). Estado inicial: PENDENTE.

Diagrama de Estados (UML) – Ciclo de vida do Atendimento

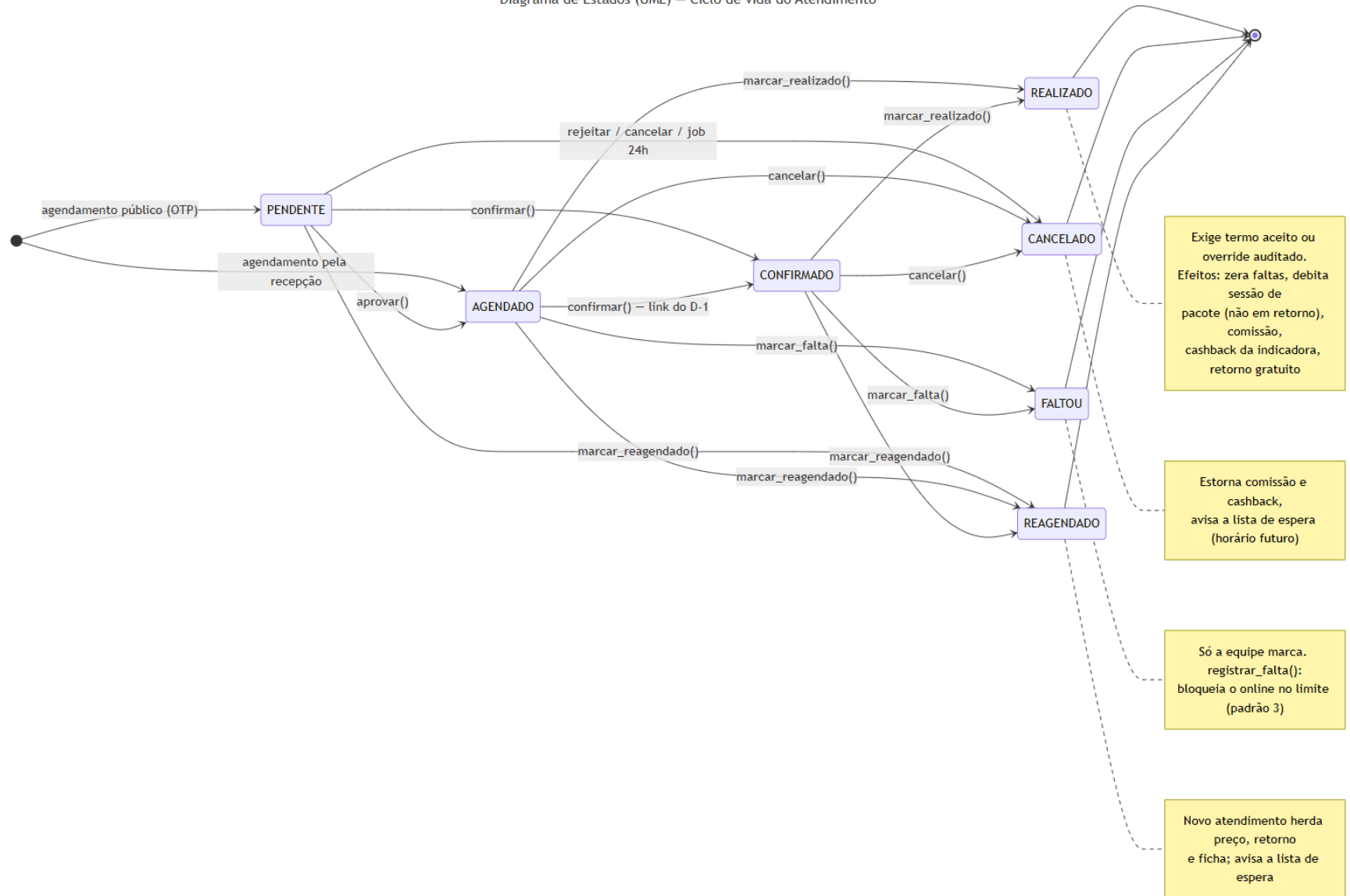


Figura 6 — Diagrama de Estados (UML): ciclo de vida do Atendimento.

8.1 Tabela de transições

Estado origem	Estado destino	Ação / gatilho
PENDENTE	AGENDADO	aprovar() — clínica aprova o pedido (painel ou portal)
PENDENTE	CONFIRMADO	confirmar()
PENDENTE	CANCELADO	cancelar() — rejeitar pedido, cliente cancela ou job limpeza_status (vencido há 24 h)
PENDENTE	REAGENDADO	marcar_reagendado() — reagendamento
AGENDADO	CONFIRMADO	confirmar() — cliente confirma pelo link do lembrete D-1 ou equipe
AGENDADO	REALIZADO	marcar_realizado() — exige termo aceito ou override auditado
AGENDADO	CANCELADO	cancelar()
AGENDADO	FALTOU	marcar_falta() — só a equipe
AGENDADO	REAGENDADO	marcar_reagendado()
CONFIRMADO	REALIZADO	marcar_realizado() — exige termo aceito ou override auditado
CONFIRMADO	CANCELADO	cancelar()
CONFIRMADO	FALTOU	marcar_falta() — só a equipe
CONFIRMADO	REAGENDADO	marcar_reagendado()

8.2 Efeitos automáticos (signals / EventBus / jobs)

- Toda transição: _transicionar trava a linha (select_for_update), valida TRANSICOES contra o status atual do banco, grava status + LogAuditoria na mesma transação (auditoria em savepoint). Transição inválida levanta Atendimento.TransicaoInvalida (a tela mostra a mensagem).
- Criação (post_save): push "Novo agendamento" ao profissional e sync com o Google Calendar, ambos no on_commit e best-effort.
- → REALIZADO (signals): zera faltas e desbloqueia a cliente; debita 1 sessão do pacote que vence primeiro (nunca em retorno; validade conferida na data da sessão). EventBus AtendimentoRealizado: comissão (base = valor cobrado, ou valor pago do pacote ÷ sessões), cashback da indicadora no 1º atendimento pago, retorno obrigatório (PENDENTE, valor 0) se o procedimento exige.
- → FALTOU (signals): registrar_falta — soma falta e bloqueia o agendamento online ao atingir o limite (padrão 3). Evento AtendimentoFaltou sem handler.
- → CANCELADO: EventBus AtendimentoCancelado estorna comissão e cashback; signals avisa a lista de espera (se o horário é futuro).
- → REAGENDADO: signals avisa a lista de espera (se o horário é futuro); sem evento de domínio.
- → CONFIRMADO: evento AtendimentoConfirmado só registra log.
- Lista de espera (mecanismo único): a seleção dos pedidos compatíveis roda na transação de quem liberou a vaga; e-mail e WhatsApp saem no on_commit; notificado só com entrega.
- NPS e lembrete D-1 não são disparados por transição: vêm dos jobs nps_24h e lembrete_diario (cron HTTP).
- PENDENTE vencido há 24 h → CANCELADO pelo job limpeza_status; AGENDADO/CONFIRMADO sem desfecho só vão para o log (a equipe decide).
- EventBus síncrono, in-process e best-effort: falha de handler é logada e não desfaz a transição.

9. Diagrama de Sequência — Agendamento com OTP

Fluxo do agendamento público: verificação do celular por OTP via SMS (exigida em todo agendamento), aceites e consentimentos com prova, controle de concorrência do horário e criação transacional do atendimento PENDENTE.

Diagrama de Sequência (UML) – Agendamento público com OTP por celular

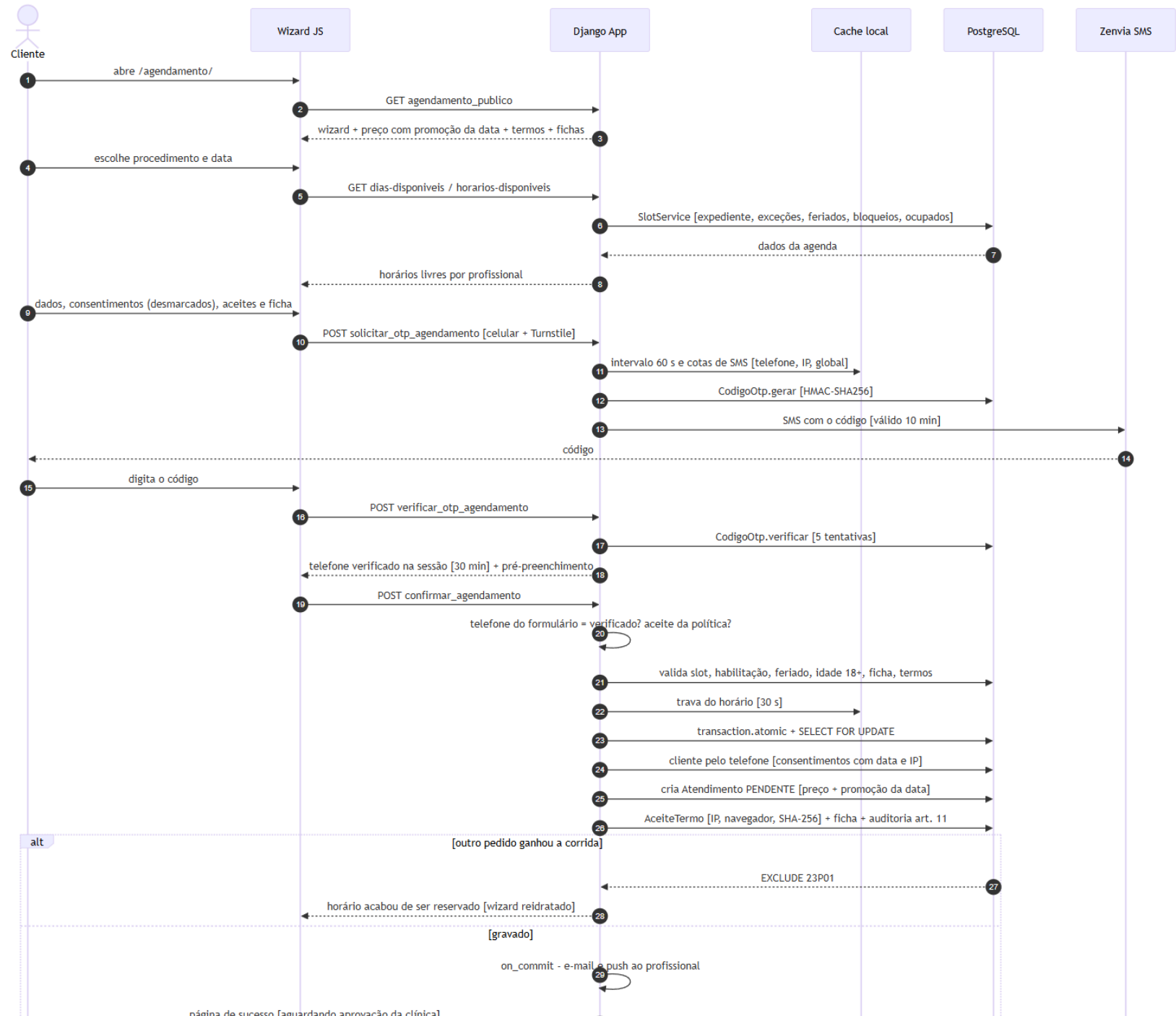


Figura 7 — Diagrama de Sequência (UML): agendamento público com OTP.

9.1 Passo a passo

1. 1. Cliente abre /agendamento/ (GET agendamento_publico) e recebe o wizard com procedimentos (preço com a promoção da data), fichas de anamnese aplicáveis, termos e a chave do Turnstile.
2. 2. Ao escolher procedimento e data, o wizard.js consulta /ajax/dias-disponiveis/ e /ajax/horarios-disponiveis/; o SlotService devolve os horários livres por profissional.
3. 3. Cliente preenche nome, celular, nascimento, e-mail (opcional), escolhe os consentimentos de comunicação (desmarcados), aceita a Política de Privacidade e os termos do procedimento e responde a ficha (com o consentimento do art. 11).
4. 4. Pede o código: POST solicitar_otp_agendamento (5/min por IP) valida o Turnstile, recusa telefone fixo, checka intervalo de 60 s e cotas de SMS antes de gerar o código (HMAC) e envia pela Zenvia (válido 10 min). A resposta não revela se o telefone é cadastrado.
5. 5. Digita o código: POST verificar_otp_agendamento confere (5 tentativas), troca o id da sessão e grava o telefone verificado (30 min); devolve o pré-preenchimento do cadastro daquele telefone.
6. 6. Confirma: POST confirmar_agendamento (10/min por IP) checka honeypot, campos obrigatórios, aceite da política e se o telefone do formulário é o verificado na sessão.
7. 7. O servidor valida e-mail, idade ≥ 18 , procedimento/profissional ativos e habilitação, data futura, feriado, slot livre (SlotService), ficha contra o schema + consentimento art. 11, termos de procedimento aceitos e e-mail que não pertença a outro cadastro.
8. 8. Trava o slot no cache (30 s) para serializar confirmações simultâneas.
9. 9. Em transaction.atomic: get_or_create da cliente pelo telefone com SELECT FOR UPDATE (bloqueada online é recusada), atualiza nome, e-mail e consentimentos (data + IP), confere conflito com SELECT FOR UPDATE, calcula preço + promoção da data e cria o atendimento PENDENTE.
10. 10. Na mesma transação grava os aceites (AceiteTermo.registrar: LGPD vigente + termos, com IP, navegador e SHA-256), as fichas respondidas e a auditoria do consentimento de saúde.
11. 11. Se outro pedido ganhou a corrida, a constraint EXCLUDE (23P01) vira a mensagem "horário acabou de ser reservado" e o wizard é reidratado.
12. 12. Após o commit: e-mail ao profissional com link para a agenda do dia, push ao profissional e sync do Google Calendar (on_commit).
13. 13. A sessão de OTP é limpa e a página de sucesso mostra o resumo (valor com promoção) e que o pedido aguarda a aprovação da clínica.
14. 14. Depois, a clínica aprova (AGENDADO + e-mail de confirmação) ou rejeita (CANCELADO + e-mail) pelo painel ou pelo portal do profissional.

10. Arquitetura e Integrações

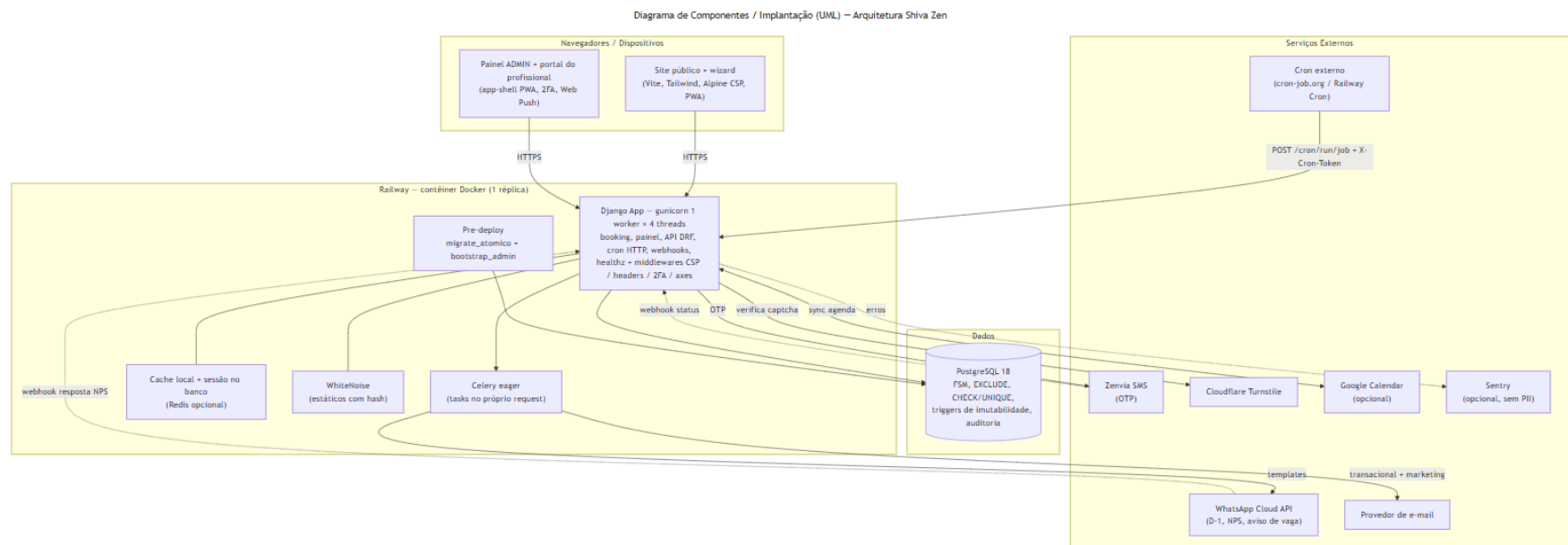


Figura 8 — Diagrama de Componentes / Implantação (UML).

10.1 Componentes

Componente	Papel
Django App (gunicorn)	Aplicação monolítica Django 5.2 (app aranha_estetica + projeto clinica), server-render, servida por gunicorn com 1 worker × 4 threads (timeout 120 s, access log com tokens redigidos). Site público, portal do profissional, painel, API REST somente leitura, cron HTTP, webhooks e healthchecks.
Middlewares de segurança	ContentSecurityPolicyMiddleware (CSP com nonce), SecurityHeadersMiddleware (no-store nas áreas privadas, no-referrer nas rotas com token, COOP/CORP/Permissions-Policy), Enforce2FAMiddleware (2FA da equipe a cada request), django-axes e django-ratelimit.
Serviços, FSM, signals e EventBus	Regras em services/ e utils/ (SlotService, OTP, preços, termos, LGPD, alertas, comissão, cashback, retorno, lista de espera). FSM do atendimento no model; signals para faltas, pacote, lista de espera e push; EventBus síncrono para comissão, cashback e retorno.
Celery (eager) + cron HTTP	Tasks Celery rodam em modo eager em produção (sem worker e sem retry síncrono); jobs periódicos chamados por cron externo em /cron/run/<job>/. Worker real opcional (CELERY_WORKER_ENABLED).
PostgreSQL 18	Banco principal (34 tabelas de domínio) com EXCLUDE anti double-booking, UNIQUE parciais, CHECKs, triggers de imutabilidade e collation pt_br. SQLite em desenvolvimento e testes rápidos.
Cache e sessão	LocMemCache + sessão no banco (1 worker): rate-limit, axes, trava de slot e cotas de SMS. REDIS_URL opcional troca para Redis (necessário com mais de um worker).
Front-end (Vite + Tailwind + Alpine + cotton)	Bundle Vite com Tailwind v4 e Alpine CSP servido pelo django-vite; componentes django-cotton; JS estático do wizard; estáticos com hash e compressão pelo WhiteNoise.
PWA e Web Push	Manifest do site e da equipe, service worker v7 (só páginas públicas em cache), push VAPID ao profissional.
Railway (Docker)	Imagem multi-stage (Node 22 → Python 3.12), pre-deploy com migrate_atomico + bootstrap_admin, healthcheck /healthz/, 1 réplica.

10.2 Integrações externas

Serviço	Uso
Zenvia SMS	Único canal de OTP (agendamento, Meus agendamentos, DSAR), só para celular, com cotas por telefone/IP/global. Sem provedor: falha fechada e o site orienta o WhatsApp. Webhook de status com IP permitido e/ou HMAC.
WhatsApp Cloud API (Meta)	Templates aprovados: lembrete D-1 com links de confirmar/cancelar, NPS pós-atendimento e aviso de vaga da lista de espera; sempre com consentimento. Webhook com handshake e assinatura X-Hub-Signature-256 captura a nota de NPS.
Provedor de e-mail	Backend Django configurável (SMTP ou HTTP): aprovação/rejeição, cancelamento, termos, lista de espera, pacote expirando, aviso ao profissional, reset/convite de senha, contato, aniversário e promoções (com List-Unsubscribe e HTML sanitizado). Sem backend real nada é enviado.
Cloudflare Turnstile	Captcha no pedido de código SMS (wizard e Meus agendamentos), verificado no servidor com o IP da cliente.
Google Calendar (opcional)	OAuth por profissional: envio do atendimento novo e leitura de eventos; feed iCal próprio com token rotacionável.
Sentry (opcional)	Monitoramento de erros com PII e tokens removidos antes do envio.
Railway	Hospedagem (Docker), Postgres gerenciado, variáveis de ambiente e agendamento (Railway Cron, opcional).

Histórico de Versões

Versão	Data	Descrição
2.1	21/06/2026	Documento de requisitos + modelagem UML gerado a partir do código (pós-auditoria SWE de backend e migração do front-end para base_v2).
2.2	23/09/2026	Atualização pós-auditoria pré-produção: OTP obrigatório em todo agendamento, consentimentos LGPD/art. 11 com prova de aceite imutável, 2FA obrigatório para ADMIN, histórico do prontuário, agendamento interno, deploy por Docker + migração atômica (migrations 0040–0046).